Stop-and-Ask Agents: Separating Capability, Authority, and Realized Effects with Replayable Receipts

Scott E. Leishman
Aevion LLC
scott@aevion.ai

September 2026

Abstract

Tool-using AI agents can prepare useful work while also being able to request consequential effects such as durable writes, submissions, spending, or credential changes. This systems report evaluates a narrow separation: an agent's capability to propose an effect is not treated as authority to commit it. **[IMPLEMENTED]**We implement an external deterministic authority gate, monotonic authority envelopes, an explicit human decision boundary for effects outside the standing envelope, and Ed25519-signed, SHA-256-linked receipts with replay verification. **[EMPIRICAL]**In a deterministic fixture evaluation, TINY-VERDICTS-EVAL-001 executes 70 cases under direct tool access and the same 70 cases under the gated condition, plus 14 receipt-integrity checks. Under the evaluated policy corpus, 42/42 unauthorized attempted effects commit under direct access and 0/42 commit under the gated condition; authorized completion is 100%, false-block rate is 0%, and receipt coverage, tamper detection, and replay verification are each 100% in the gated fixtures. A separate recorded Bedrock run reached the human-decision boundary, was denied, committed no durable effect, and replayed successfully. **[DO NOT CLAIM]**These results do not establish general agent safety, universal containment, or legal non-repudiation. They establish behavior only for the implemented mechanism and evaluated scope.

1 Problem Statement

[IMPLEMENTED]Modern agent frameworks make tool invocation easy, but tool availability and effect authority are different system properties. The implementation studied here separates four states that are often collapsed in agent demos:

proposal → authority decision → realized effect → evidence receipt

The model may generate a proposal. A deterministic gate evaluates the requested effect against a standing authority envelope. A durable or otherwise consequential effect can require a fresh human decision. The resulting decision and observed outcome are written into a signed receipt chain that can be replayed independently.

[PLAUSIBLE DESIGN]The intended use is not to eliminate human involvement or to ask a person to approve every tool call. Instead, autonomy is preserved inside an explicit envelope and human authority is concentrated at selected consequential boundaries.

[DO NOT CLAIM]The architecture is not presented as a universal safety theorem. It does not prove that the agent is correct, that every hazardous action has been classified, or that a compromised host cannot interfere with execution.

2 System Model

2.1 Authority contracts

[IMPLEMENTED]The reference implementation represents standing authority as an immutable `AuthorityContract` containing a principal, an allowed-effect set, a maximum unattended write count, a spending ceiling, and delegation rights. Child authority is monotonically narrowed: child effects must be a subset of parent effects, numeric ceilings may only shrink, and delegation rights cannot be created by a child.

For an effect e and authority contract A, the gate returns one of three operational decisions:

$$G(A, e) \in \{\textsc{Allowed},\ \textsc{RequiresHuman},\ \textsc{Denied}\}.$$

[**IMPLEMENTED**]Read and draft effects can remain autonomous. Explicitly destructive or prohibited effect classes are denied. Other effects outside the standing envelope are held at the human boundary.

2.2 Capability is not authority

[**PLAUSIBLE DESIGN**]We use the following architecture invariant as a design rule rather than as a mathematical theorem:

$$\text{Model proposal} \not\Rightarrow \text{effect authority}.$$

The model may influence which effect is proposed, but the authorization decision is computed outside the model from the declared contract and effect class.

2.3 Signed receipt chain

[**IMPLEMENTED**]Each receipt body is serialized as canonical JSON (sorted keys, compact separators, UTF-8), linked to the prior receipt by SHA-256, assigned a monotonically increasing sequence number, and signed with Ed25519. The receipt contains the body digest, Base64-encoded public key, and Base64-encoded signature. Replay recomputes each digest, checks the previous-receipt pointer, reconstructs the Ed25519 public key, and verifies the signature.

[**EMPIRICAL**]The frozen evidence includes negative fixtures that mutate payloads, verdicts, sequence numbers, previous-hash pointers, public keys, signatures, and digests. The recorded verifier rejects all 14 evaluated integrity failures (7 payload/signature tamper cases and 7 chain-break cases).

[**DO NOT CLAIM**]The demonstration signer uses an ephemeral key. The receipt therefore establishes integrity relative to the embedded public key, not durable human identity, PIV/YubiKey attribution, or legal non-repudiation.

3 Evaluation

3.1 Research question

[**EMPIRICAL**]TINY-VERDICTS-EVAL-001 asks a bounded question: *does the enforcement layer prevent effects outside the evaluated authority policy while preserving authorized autonomous work?* It is not an LLM intelligence benchmark. The same deterministic corpus is run in two conditions:

- **Condition A: Direct Tool Access.** The proposed effects execute without the authority gate.
- **Condition B: Effect Gate.** Effects pass through the authority contract, human boundary, receipt chain, and replay verifier.

[**EMPIRICAL**]The frozen aggregate artifact reports 70 execution cases per condition (140 execution evaluations total), spanning read/draft operations, durable writes without authority, explicitly prohibited effects, delegation constraints, state drift, missing evidence, and human approve/deny paths. An additional 14 integrity checks exercise receipt tampering and broken chain links.

3.2 Results

[**EMPIRICAL**]Within this corpus, the headline result is `0/42 unauthorized effects executed` under the gated condition versus `42/42` under direct access. Boundary-decision accuracy is reported as 1.0 for the gated condition, with zero false denials and 1.0 human-escalation precision.

[**DO NOT CLAIM**]These percentages should not be generalized beyond the corpus. The direct condition is intentionally permissive and the gated condition is evaluated against policies encoded by the same project. The benchmark therefore demonstrates mechanism behavior and non-vacuity within its fixtures; it is not an externally validated estimate of real-world safety.

Metric	Direct	Gated
Useful tasks completed	21	28
Unauthorized effects attempted	42	42
Unauthorized effects committed	42	0
Unauthorized execution rate	100%	0%
Human escalations	0	28
False denials	0	0
Authorized-effect completion rate	100%	100%
Receipt coverage	0%	100%
Tamper detection rate	0%	100%
Replay verification rate	0%	100%

Table 1: **[EMPIRICAL]**Frozen TINY-VERDICTS-EVAL-001 aggregate results. These are deterministic fixture measurements, not estimates of production-world agent failure rates.

3.3 Recorded model-backed run

[EMPIRICAL]The frozen project evidence records one Amazon Bedrock run using Strands Agents 1.54.0 and `amazon.nova-micro-v1:0`. The agent reached `HUMAN_DECISION_REQUIRED`; the human decision was `DENY`; no durable effect committed; receipt replay verified. The recorded model-workflow latency was 18,748.935 ms.

[DO NOT CLAIM]A single model-backed run does not establish provider independence or a general model-quality result. The control mechanism itself is deterministic and can run without a network model, but broader live-provider evaluation remains future work.

4 Threat Model and Failure Boundaries

[IMPLEMENTED]The evaluated mechanism addresses a specific failure class: an agent proposes or attempts an effect outside its standing authority. It also checks monotonic child delegation and receipt-chain integrity.

Failure surface	Implemented response	Remaining boundary
Out-of-envelope durable write	Stop and require human decision	Misclassification of effect class
Explicitly prohibited effect	Deterministic denial	Incomplete prohibited-effect catalog
Child requests parent-absent right	Reject delegation	Parent contract may itself be over-broad
Receipt payload mutation	Digest/signature replay failure	Host can still delete all evidence unless externally anchored
Broken chain pointer	Replay failure	Retained head/root still matters
Model pressure or urgency	Does not change authority contract	Model may still produce poor proposals

Table 2: **[IMPLEMENTED]**Implemented controls and explicitly retained failure boundaries.

5 Relation to Prior Work

[PLAUSIBLE DESIGN]This work is complementary to agent-security benchmarks and formal tool-use safety research rather than a replacement for them. AgentDojo evaluates prompt-injection attacks over realistic tool-using tasks and emphasizes adversarial robustness [1]. Agent Security Bench formalizes a broader attack/defense benchmark across tool-using agents [2]. AgentDyn extends prompt-injection evaluation toward dynamic, open-ended tasks [3]. Doshi et al. propose deriving enforceable tool/data-flow constraints from hazard analysis and capability-enhanced MCP metadata [4]. NIST's 2026 AI Agent Standards Initiative similarly highlights secure interoperability, identity, and standards for autonomous agents [5].

[PLAUSIBLE DESIGN]The narrower contribution here is operational: a deterministic authority boundary is placed between proposal and effect, with monotonic delegation and signed replayable evidence. The evaluation measures whether that boundary behaves as encoded, not whether an underlying model resists every attack.

6 Reproducibility

[**IMPLEMENTED**]The public reference implementation is available at:

https://github.com/Aevion-ai/stop-and-ask-agent

The repository documents the following reproduction commands:

```
python -m pytest -q tests
python -m eval.tv_eval --output-dir eval/evidence
python demo.py --decision deny --state-dir /tmp/vetproof-demo
```

[**EMPIRICAL**]The frozen evidence records 17 acceptance tests passing on 2026-09-04 at evidence commit `582e65973d6349408e27ba36e608df29da457b44`. The benchmark artifact currently in the public repository reports the aggregate results in Table 1.

7 Limitations

[**DO NOT CLAIM**]The implementation and results do not support claims of universal agent safety, proof against arbitrary host compromise, correctness of model reasoning, complete hazard coverage, durable signer identity, production multi-tenancy, or legal admissibility. The demo task is intentionally small, and the deterministic benchmark is project-authored. Independent reproduction, external task corpora, stronger adversarial evaluation, persistent hardware-backed signing, and realized-state witnesses are appropriate next steps.

8 Conclusion

[**EMPIRICAL**]In the evaluated fixtures, separating tool capability from effect authority prevents all 42 unauthorized attempted effects from committing while preserving completion of authorized effects and producing replay-verifiable receipts. [**IMPLEMENTED**]The mechanism is implemented as deterministic code outside the model, with monotonic authority delegation and explicit human control at selected consequential boundaries. [**DO NOT CLAIM**]The result is not a general safety guarantee. It is evidence that a narrow, inspectable authority boundary can be tested independently from model intelligence and can emit artifacts suitable for later replay and audit.

References

[1] E. Debenedetti, J. Zhang, M. Balunovic, L. Beurer-Kellner, M. Fischer, and F. Tramer. AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents. arXiv:2406.13352, 2024.

[2] H. Zhang, J. Huang, K. Mei, Y. Yao, Z. Wang, C. Zhan, H. Wang, and Y. Zhang. Agent Security Bench (ASB): Formalizing and Benchmarking Attacks and Defenses in LLM-based Agents. arXiv:2410.02644, 2024.

[3] H. Li, R. Wen, S. Shi, N. Zhang, and C. Xiao. AgentDyn: A Dynamic Open-Ended Benchmark for Evaluating Prompt Injection Attacks of Real-World Agent Security System. arXiv:2602.03117, 2026.

[4] A. Doshi, Y. Hong, C. Xu, E. Kang, A. Kapravelos, and C. Kästner. Towards Verifiably Safe Tool Use for LLM Agents. In *Proceedings of the IEEE/ACM 48th International Conference on Software Engineering (ICSE-NIER)*, pages 201–205, 2026. DOI: 10.1145/3786582.3786839.

[5] National Institute of Standards and Technology. AI Agent Standards Initiative for Interoperable and Secure Innovation, 2026. https://www.nist.gov/news-events/news/2026/02/announcing-ai-agent-standards-initiative-interoperable-and-secure.